

 PREMIER® POLICY AND PROCEDURE	TITLE: Security and Privacy Violations and Sanctions Policy and Procedure	
	DATE CREATED: 11/06/2017	VERSION NUMBER: 3
	DATE OF LAST REVIEW: 08/16/2022	DEPARTMENT OWNER: Corporate Compliance

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

1. Purpose

To establish the Policy and Procedure for sanctioning Premier workforce members who violate Premier security and privacy policies, procedures, standards and processes, as well as state and federal regulations.

2. Scope

Applies to Premier, Inc., its Affiliates and all workforce members with direct or indirect access to Premier's Information Security Management System, Premier Information or Premier Information Assets.

It is the responsibility of each Premier workforce member to promptly report real or suspected security or privacy incidents, violations, potential breaches, and noncompliance with Premier's security and privacy policies, standards, processes and procedures, as well as state and federal regulations, in accordance with the *Reporting a Suspected Security or Privacy Incident or Violation Policy and Procedure*.

3. Definitions

Access – The ability or the means necessary to view, read, write, modify or communicate data/information or otherwise use any system resource.

Affiliate(s) – Any entity that, directly or indirectly through one or more entities, controls or is controlled by, or is under common control with Premier; “controls,” “control” and “controlled” mean the possession, direct or indirect, of the power to direct the management and policies of an entity, whether through the ownership of fifty percent (50%) or more of the voting interests of such entity or otherwise.

Breach – The unauthorized acquisition, access, use, or disclosure of information which compromises the security or privacy of such information, except where an unauthorized person to whom such information is disclosed would not reasonably have been able to retain such information.

Disclosure – The release, transfer, provision of, access to or divulging in any other manner of information outside the entity holding the information.

Disseminate – To disperse throughout.

Incident – A single or a series of unwanted or unexpected security or privacy events that result in harm, or pose a significant threat of harm, to Premier Information and/or Premier's Information Security Management System and require non-routine preventative or corrective action.

Information Assets – A body of knowledge that is organized and managed as a single entity and anything that has value to Premier. It is an identifiable collection of data stored in any manner and recognized as having value for the purpose of enabling Premier to perform its business functions and operations.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

Information Security Management System (ISMS) – A set of policies and procedures for systematically managing an organization's protected data. Premier's ISMS is designed to minimize risk and ensure business continuity by pro-actively limiting the impact of a security or privacy breach to Premier's systems and/or computers, which include but are not limited to, laptops and network devices used to process Premier information.

Personally Identifiable Information (PII or "Personal Information") – Any information about an individual, including any information that can be used to distinguish or trace an individual's identity, such as name, social security number, date and place of birth, mother's maiden name or biometric records; and any other information that is linkable to an individual, such as medical, educational, financial and employment information.

Premier – Includes Premier, Inc. and its Affiliates.

Premier Information – Includes Premier Internal Information and Premier Restricted Information that may be accessed, used and disclosed by workforce members of Premier and third parties as authorized, but not to the public. Premier Information includes documents, materials, records and electronic data processed, stored or maintained in any manner in Premier's Information Security Management System and deemed proprietary by Premier or held in confidence by Premier for a Premier customer. Such information may include intellectual property, trade secrets, customer data and information, and is considered confidential in nature, and subject to protection under Premier policies.

Premier Internal Information – Consists of information and documents, processed, stored or maintained by Premier that may be accessed, used and disclosed by Premier workforce members and authorized third parties to perform job related services or for general work-related information. Examples of Premier Internal Information include, but are not limited to: organizational charts, policies and procedures, project Information and restricted customer/member listings.

Premier Restricted Information - Consists of information that is sensitive or private, of high value to Premier and/or its customers, requires tight controls over distribution, and is intended for use by a limited number of identified internal or external individuals (subject to strict confidentiality agreement or other agreement) expressly authorized by the owner of the information or document. Restricted Information must be controlled from creation to destruction and will be granted only to those authorized persons who require such access in order to perform their job, or those individuals permitted by law. Examples of Restricted Information include but are not limited to: Premier proprietary information and intellectual property ("IP"), Personally Identifiable Information ("PII"), Payment Card Information ("PCI"), Protected Health Information ("PHI") and Authentication Information.

Privacy Incident – The loss of control, compromise, unauthorized disclosure, unauthorized acquisition, unauthorized access or any similar term referring to situations where persons other than authorized users, have access or potential access to Premier Information in usable form, whether physical or electronic, or where authorized users access Premier Information for an unauthorized purpose. The term encompasses both suspected and confirmed incidents involving Premier Information which raise a reasonable risk of harm.

Protected Health Information (PHI) – A subset of Premier Restricted Information. Specifically, it is health information that is collected about an individual that (1) is created or received by or on behalf of a covered entity, health care provider, health plan or health care clearinghouse; (2) relates to the past, present or future physical or mental health or condition of an individual, the provision of health care to an individual or the past, present or future payment for the provision of health care to an individual; and (3) identifies the individual or with respect to which there is a reasonable basis to believe the information can be used to identify the individual based on standards issued by the federal government.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

Public Information – Information, regardless of form or format, that the owner of the information discloses, disseminates or makes available to the public, and which is available to a wide range of persons.

Retaliation – Any action, statement or behavior that is designed to punish an individual for filing an incident report, cooperating with an incident investigation, seeking guidance regarding a security or privacy concern or to deter one from taking such action. Retaliation includes, but is not limited to, bullying, intimidation and any adverse action against a workforce member regarding the terms and conditions of employment, such as termination, demotion or suspension as well as related threats of such actions.

Sanction – The penalty for noncompliance with Premier policies, procedures, standards and processes as well as state and federal regulations.

Security – All of the administrative, physical and technical safeguards in an information system.

Security Incident – The attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in an information system containing or processing protected data.

Use – The sharing, employment, application, utilization, examination or analysis of such information with an entity that maintains such information.

Violation – A failure to comply with Premier policies, procedures, standards and processes as well as state and federal regulations.

Workforce Member - Any individual employee, contractor or consultant with logical and/or physical access to Premier information assets and resources.

4. Attachments/References

Health Insurance Portability and Accountability Act of 1996 (HIPAA)

[Premier Data Stewardship Program \(DSP\) – Part I General Program Policies](#)

[Premier Data Stewardship Program \(DSP\) – Part IV Technical Safeguards Policies](#)

[Premier Data Stewardship Program \(DSP\) – Part V Protected Health Information](#)

Premier Disciplinary and Corrective Action Form

[Information Classification and Retention Policy](#)

[Reporting a Suspected Security or Privacy Incident or Violation Policy and Procedure](#)

[Non-Retaliation Policy](#)

POLICY

1. All forms of Premier Information in use, whether created, obtained and/or owned by Premier, are a valuable asset and must be protected from all known security and privacy risks. These risks include, but are not limited to, unauthorized access, use, disclosure, modification, destruction and removal of Premier Information. All forms of Premier Information are covered by this Policy, including but not limited to, paper, any systems used to capture electronic data and any media used for creating, obtaining, capturing, accessing, using or disclosing Premier Information of any kind.
2. In accordance with this Policy, Premier's Chief Information Security Officer and Chief Privacy Officer work with, as deemed necessary, Human Resources, Legal counsel, Information Security, the workforce member's manager and Premier leadership to evaluate,

Confidential information of Premier, Inc. and Premier Healthcare Alliance, L.P. Not to be reproduced, copied or distributed without prior written consent of Premier, Inc. and Premier Healthcare Alliance, L.P.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

investigate, develop and administer in a consistent manner, appropriate sanctions to any Premier workforce member found to have participated, engaged or violated Premier security or privacy policies, procedures, standards, processes, or state and federal regulations.

3. Upon completion of the investigation by Premier's Chief Information Security Officer and Chief Privacy Officer, Premier may impose sanctions against workforce members and may report to applicable state and federal authorities, if it is determined that a workforce member participated, engaged or violated Premier security or privacy policies, procedures, standards, processes, or state and federal regulations.

Violations

4. Premier appropriately disciplines any workforce member found to have violated Premier's security or privacy policies, procedures, standards, processes, or state and federal regulations to a degree appropriate for the severity of the violation.
5. The following is a non-exhaustive list of actions which may violate Premier security or privacy policies, procedures, standards, processes, or state and federal law:
 - 5.1 Improper use, access or disclosure of Premier Information.
 - 5.2 Improper use, access or disclosure of Premier Information which violates state and federal privacy, security, or identity theft protection law.
 - 5.3 Improper dissemination of Premier Information, including but not limited to, a personal electronic mail account, personal drop box or storage device (i.e., internal and external hard drives, CDs, DVDs, Floppy Disks, USB drives, Zip Disks, magnetic tapes, SD Cards, etc.) without authorization.
 - 5.4 Improper dissemination of Premier Information without authorization.
 - 5.5 Using Premier resources to threaten, harass or intimidate others.
 - 5.6 Using Premier resources to engage in illegal activities.
 - 5.7 Using Premier resources without authorization to electronically scan, probe, attempt unauthorized access, or disable either Premier or non-Premier systems.
 - 5.8 Theft of Premier Information or technology.
 - 5.9 Unauthorized distribution, knowledge or use of software including pirated software.
 - 5.10 Improper or excessive use of Premier resources for non-business purposes such as excessive use of electronic mail or internet access for personal use.
 - 5.11 Unauthorized attempts to bypass Premier Information and data security controls such as anti-virus, web filters, firewalls, etc.
 - 5.12 Inappropriate sharing of credentials such as passwords and identification/access cards.
 - 5.13 Inappropriate viewing, displaying or storing of materials (e.g., images, video, audio, etc.) that is not in keeping with the standards of Premier and/or may otherwise violate state or federal law.
 - 5.14 Inappropriate viewing, displaying or storing of materials (e.g., images, video, audio, etc.) that creates a hostile or threatening work environment.
 - 5.15 Failure to wear authorized access badges in plain view while on Premier premises.
 - 5.16 Demonstration of reckless disregard for the protection of Premier Information, Premier Information Assets or Premier technology (e.g., ignoring backup and recovery procedures, failure to log out of systems/applications, failure to implement virus software, etc.).
 - 5.17 Abuse of Premier Information Assets, Premier Information or Premier technology by individuals assigned access privileges.
 - 5.18 Creation of a denial-of-service condition (e.g., causing a system failure, locking out other users, etc.).
 - 5.19 Compromise of integrity (e.g., changing information and/or software in an unspecified or unauthorized manner).
 - 5.20 Propagation of viruses, trojan horses, worms, time bombs or other malicious code.
 - 5.21 Making unauthorized copies of Premier Information.
 - 5.22 Disclosing, copying, changing or discussing Premier Information without authorization.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

- 5.23 Using personal email addresses and/or unauthorized email accounts to conduct Premier business.
- 5.24 Forwarding Premier Information to personal and/or unauthorized email accounts.
- 5.25 Failing to notify Premier's Privacy and Security teams of a potential privacy or security incident.
- 5.26 Sending Premier Information, whether paper or electronic, to an unauthorized individual, member, customer or business.
- 5.27 Failing to properly verify recipient of Premier Information.
- 5.28 Failing to send Premier Information through secure means.
- 5.29 Sending Premier Information to a third-party without appropriate, Legal-approved agreements in place.

Sanctions

- 6. Premier's security and privacy policies, procedures, standards and processes reflect the same high standards of ethics and quality established for all aspects of Premier's business. Violation of any Premier security or privacy policies, procedures, standards or processes provides a basis for disciplinary action up to and including termination of employment. A violation may also have legal consequences.
- 7. Premier appropriately disciplines workforce members for violations of Premier security or privacy policies, procedures, standards, processes, and state and federal regulations, to a degree appropriate for the severity of the violation.

Possible Sanctions

- 8. Depending on the severity of an event, vulnerability and/or violation, Premier's Chief Information Security Officer and Chief Privacy Officer, in conjunction with Human Resources, Legal counsel, Information Security, the workforce member's manager and Premier leadership, may take disciplinary action to impose sanctions that include, but are not limited to, the following:
 - 8.1 Verbal warning which may be filed within the employee's personnel file.
 - 8.2 Written warning which may be filed within the employee's personnel file.
 - 8.3 Suspension filed within the employee's personnel file.
 - 8.4 Additional education or training requirements.
 - 8.5 Termination of employment.
 - 8.6 Civil penalties imposed by state and/or federal regulations.
 - 8.7 Criminal penalties imposed by state and/or federal regulations.

Non-Retaliation

- 9. Premier expects its workforce members to promptly report security and privacy concerns, issues or suspected violations following the procedure in the *Reporting a Suspected Security or Privacy Incident or Violation Policy and Procedure*, if they have observed suspected criminal or illegal activity, unethical behavior or conduct that violates, or may violate, this Policy.
- 10. In conjunction with Premier's *Non-Retaliation Policy*, Premier prohibits any retaliatory action against a workforce member who has made a good faith internal report of real or suspected privacy or security incidents, violations, potential breaches, and noncompliance with Premier's security and privacy policies, standards, processes and procedures even if subsequent investigation proves the report to be unfounded. However, those who make a report of their own potential violation may be disciplined, if appropriate.
- 11. Any workforce member found to have violated Premier's *Non-Retaliation Policy* is subject to disciplinary action up to and including termination.

Printed copies are for reference only. Please refer to the electronic copy for the latest version.

Responsibility

12. Premier's Chief Information Security Officer and Chief Privacy Officer are responsible for the amendment and interpretation of this Policy.

PROCEDURE

13. Premier workforce members who violate Premier security or privacy policies, procedures, standards, processes, or state and federal regulations are subject to internal Premier sanctions. Workforce members who violate state and/or federal law may be subject to criminal investigation, prosecution or civil monetary penalties in addition to internal Premier sanctions.
14. Premier's Chief Information Security Officer and Chief Privacy Officer investigate any reported or suspected security or privacy incident or violation. To the extent possible, Premier's Compliance and Legal teams mitigate any negative effects related to the incident or violation. Any individual(s) involved may have their privileges revoked pending completion of the investigation. Security or privacy incidents or violations may require notification to appropriate law enforcement agencies, government regulatory agencies and affected individuals.
15. All reported real or suspected security and privacy incidents, violations, potential breaches, and noncompliance involving Premier workforce members are reported to Premier's Chief Information Security Officer and Chief Privacy Officer who notify, as deemed necessary, Human Resources, Legal counsel, Information Security, the workforce member's manager and Premier leadership. The Chief Information Security Officer and Chief Privacy Officer, or his/her designee, document the security or privacy incident or violation in accordance with this Policy and Procedure using the *Disciplinary and Corrective Action Form*.
16. If, through investigation, it is determined that a workforce member committed a security or privacy violation, he/she must expect that any internal sanction is substantial and may likely result in complete revocation of privileges and/or termination of employment. Premier and the workforce member found in violation must fully cooperate with any criminal investigation or prosecution efforts as required by law.
17. After completion of the investigation, Premier's Chief Information Security Officer and Chief Privacy Officer work with, as deemed necessary, Human Resources, Legal counsel, Information Security, the workforce member's manager and Premier leadership to determine the applicable sanction based on the individual's intent, expected and actual knowledge concerning their actions, the resulting negative effect of the act, and any directions received from federal or state agencies.

Where to Go with Questions and Concerns

Contact the Chief Information Security Officer or Chief Privacy Officer with questions or concerns about this Policy and Procedure.